Week 2- Gap Analysis: M03 Kali Audit Workstation (Kali).

Why: The audits show what is not hardened on the Kali workstation. The gap analysis groups the findings, links each group to CIS Controls v8, and says how urgent it is. It feeds the Week 3 risk register.

1-Audit facts

Item	Details
Machine	M03 – kali, Kali GNU/Linux Rolling, kernel 6.19.14+kali-amd64. My audit workstation: not an asset of the firm, so not given a CIA rating (Week 1 inventory). It stores the audit tools and the audit results.
Tool and date	Lynis 3.1.6, 6 November 2026
Result	271 tests, 0 warnings, 47 suggestions. Hardening index 61 out of 100 (higher = better hardened).
Software components	Firewall [X], Intrusion software [X], Malware scanner [X]. [X] = not found by Lynis.
Evidence	W2_Screenshots; full output in M03_Lynis_output_20261106.txt
Lynis notices (not findings)	Lynis version older than 6 months; Kali not listed in the Lynis end-of-life database. They do not change the results.

2-How to read it

• Suggestion: an improvement Lynis recommends. M03 has no warnings, so every finding here is a suggestion.

• Lynis ID (e.g. AUTH-9262): the test reference. Each one is explained on cisofy.com/lynis/controls/<ID>.

• Grouping: the 47 suggestions are put into 12 groups by subject (updates, firewall, passwords…), as for M02. Each group is linked to one CIS Control v8.

• Priority (same rule as M01 and M02): High = a basic protection is missing and client or payroll data is directly exposed; Medium = the basic protection exists but an extra layer is missing; Low = limited impact.

3-Results by theme

#	Theme	CIS Control v8	Count	Lynis IDs	Key evidence	Gap	Priority
K1	Updates and package tools	Control 7	6	DEB-0810, DEB-0811, DEB-0831, PKGS-7308, PKGS-7394, PKGS-7420	No tool to apply upgrades automatically (PKGS-7420)	Updates depend on manual action	Medium
K2	Firewall	Control 4	1	FIRE-4590	Firewall [X]: no packet filter found	No firewall found to filter traffic	Medium
K3	Passwords and logins	Control 5	6	AUTH-9230, AUTH-9262, AUTH-9282, AUTH-9286 (×2), DEB-0880	No password strength check (AUTH-9262)	Password strength not checked; repeated failed logins not blocked	Medium
K4	Malware and intrusion detection	Control 10	1	HRDN-7230	Malware scanner [X], Intrusion software [X]	No malware or intrusion detection found	Medium
K5	Logging	Control 8	4	LOGG-2154, LOGG-2190, ACCT-9622, ACCT-9626	Logs not sent to a separate system (LOGG-2154)	Hard to know what happened after an incident	Medium
K6	File integrity	Control 3 (closest)	2	FINT-4350, PKGS-7370	No file integrity tool (FINT-4350)	Changes to important files would not be detected	Medium
K7	Boot, kernel and system settings	Control 4	6	BOOT-5122, BOOT-5180, BOOT-5264, KRNL-6000, DEB-0280, HRDN-7222	No boot menu password (BOOT-5122); AppArmor disabled	Boot and kernel settings not hardened	Medium
K8	Unneeded software	Control 4	6	INSE-8300, INSE-8318, INSE-8320, HTTP-6640, HTTP-6643, PHP-2376	rsh client and TFTP packages installed (INSE-8300, INSE-8318, INSE-8320)	Software installed that may not be needed	Medium
K9	Unused protocols and storage drivers	Control 4	6	NETW-3200 (×4), USB-1000, STRG-1846	USB and FireWire storage drivers not disabled (USB-1000, STRG-1846)	Unused protocols available; data can be copied to USB	Medium
K10	File and home permissions	Control 3	3	FILE-7524, HOME-9304, AUTH-9328	Home directory permissions may not be strict enough (HOME-9304; shown as [WARNING] on screen)	Files may be readable by more users than needed	Medium
K11	Disk partitions	Control 4	2	FILE-6310 (×2)	/home and /var not on separate partitions	A full area can affect the whole system	Low
K12	Banners, DNS, config. tools	Control 4 (closest)	4	BANN-7126, BANN-7130, NAME-4028, TOOL-5002	No login banner (BANN-7126)	Users not warned; settings managed by hand	Low

K1-K12: theme numbers of Kali machine (M03). Count = number of Lynis suggestions in the theme.

CIS Controls v8 names: Control 3 = Data Protection. • Control 4 = Secure Configuration of Enterprise Assets and Software. • Control 5 = Account Management. • Control 7 = Continuous Vulnerability Management. • Control 8 = Audit Log Management. • Control 10 = Malware defenses.

All 47 suggestions are covered. Each one, with its Lynis ID, is in M03_Lynis_output_20261106.txt.

Terms used in the table

• **AppArmor :** a Linux security module that limits what each program can do.

• **GRUB**: the boot menu shown when the machine starts.

• **fail2ban:** a tool that blocks an address after repeated failed logins.

• **risk and TFTP**: old network tools; rsh sends data without encryption & TFTP has no login.

• **Kernel (sysctl) settings**: core system settings; Lynis compares them with a hardened profile.

• **unmask**: the default permissions given to new files.

4-Already in place

0 warnings in 271 tests; permissions OK on /etc/passwd, /etc/group and /boot/grub/grub.cfg • ownership of home directories OK • kernel protections fs.protected_hardlinks, fs.protected_symlinks, kernel.randomize_va_space and net.ipv4.tcp_syncookies set as expected.

5-Main result

No High gap on M03, because it holds no client or payroll data. But four basic protections are missing: automatic updates (K1), firewall (K2), password rules (K3) and malware detection (K4). They still matter: M03 stores the audit results, which describe the firm's weaknesses.

Why they are Medium and not High: on M02, the same four gaps (updates, firewall, passwords, malware scanner) are High because M02 holds client or payroll data, so here they are Medium.

Compared with M02: M03 scores higher (61 against 57) and has no warnings, but it has more suggestions (47 against 38).

6-Sources

- **Audit evidence**: W2_Screenshots; M03_Lynis_output_20261106.txt.
- **Machine facts**: W1_Asset_Inventory (M03 row).
- **Lynis**: cisofy.com/lynis (tool and version 3.1.6).
- **Lynis tests**: cisofy.com/lynis/controls/<ID> (for example cisofy.com/lynis/controls/AUTH-9262).
- **CIS Controls v8**: cisecurity.org/controls/cis-controls-list.
- **Method note**: no official Lynis-to-CIS mapping exists; linking each theme to a CIS Control is my own analysis. K6 and K12 use the closest control.